



Attack/Defense 101

University of Insubria

CTF Basics

Before diving into what a A/D CTF is, let's first do a quick recap on what a CTF is:

A CTF, or Capture The Flag, is a cybersecurity competition where participants solve various challenges across different categories. The objective is to discover a specific text string, known as a flag, often preceded by a known placeholder. Each challenge may contain one or more flags and is assigned a score. The score and the flag can be either **static** or **dynamic**.

There are two main variations, or styles, of CTFs:

- Jeopardy: Participants acquire flags from the organizers' set challenges.
- Attack/Defense: Participants, organized into teams, compete to acquire flags from other teams.

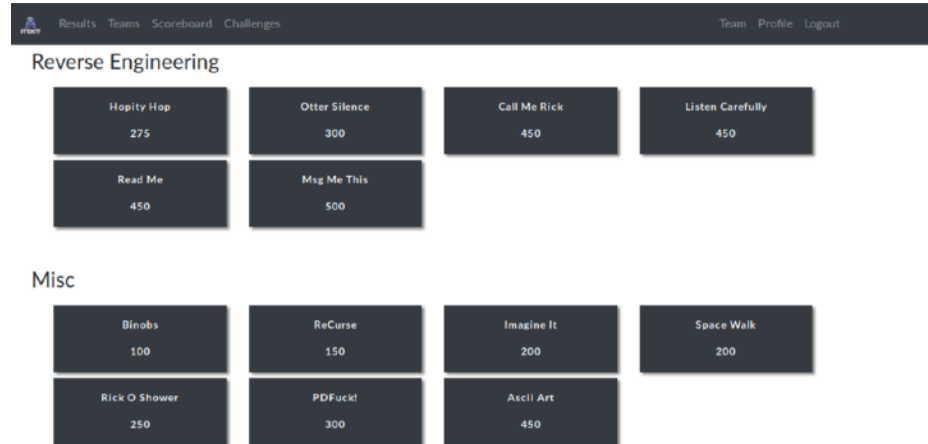
CTF Basics - Jeopardy

Jeopardy CTFs are the most common kind of CTF:

Participants compete individually or in teams to solve a set of challenges which are hosted and provided by the CTF's organizers.

Teams do not directly interact with each other during the competition, focusing solely on solving challenges.

After solving a challenge, you submit the flag in the CTF platform to earn points.



The screenshot shows a CTF platform interface with a dark theme. At the top is a navigation bar with links: Home, Results, Teams, Scoreboard, Challenges, Team, Profile, and Logout. Below the navigation bar, the challenges are organized into two categories: 'Reverse Engineering' and 'Misc'. Each category contains a grid of challenge cards, each displaying the challenge name and its point value.

Reverse Engineering			
Hopity Hop 275	Otter Silence 300	Call Me Rick 450	Listen Carefully 450
Read Me 450	Msg Me This 500		

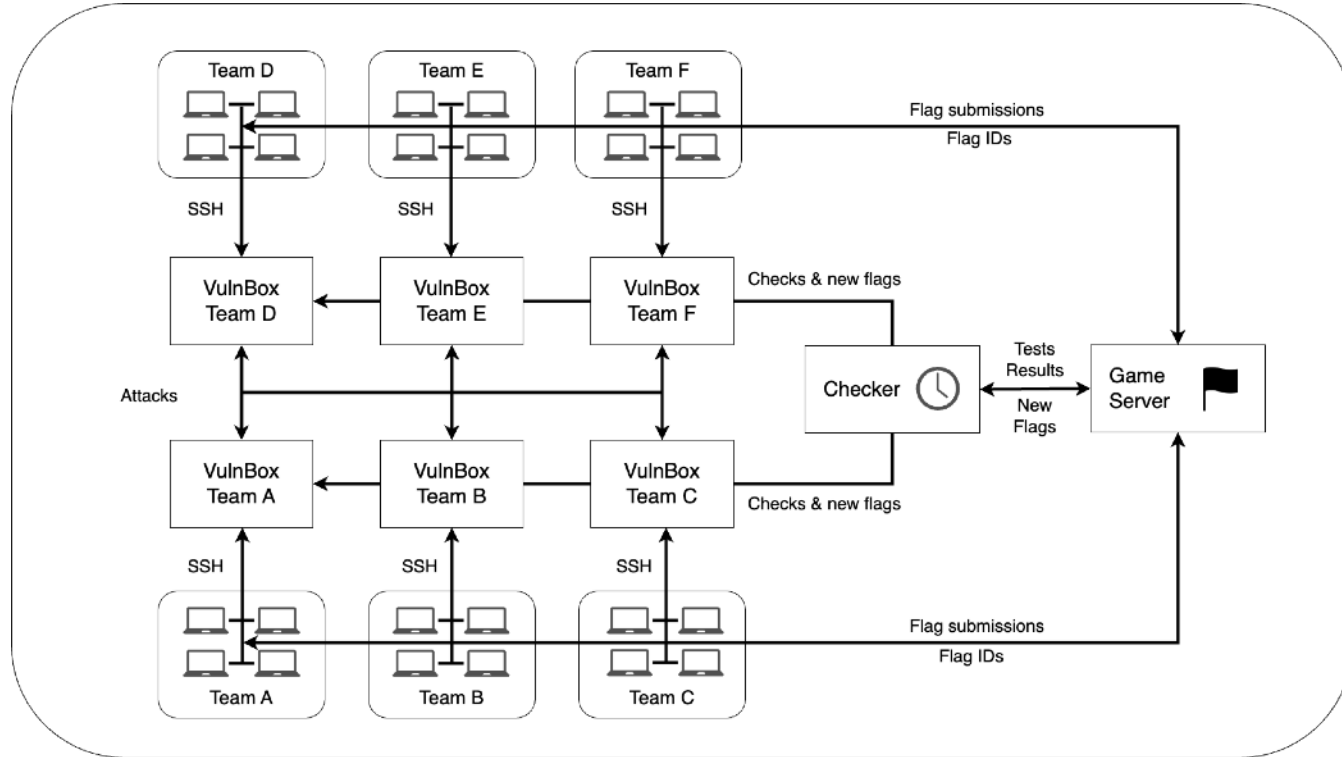
Misc			
Binobs 100	ReCurse 150	Imagine It 200	Space Walk 200
Rick O Shower 250	PDFuck! 300	Ascii Art 450	

CTF Basics - Attack/Defense

In Attack/Defense CTFs participants are divided into teams and engage in a simulated environment. Each team is tasked with defending their VM (or VulnBox) from attacks while simultaneously attempting to breach the security of opposing teams to obtain flags.

Each VulnBox has a certain number of challenges (from now on, we will refer to them as services) which have multiple vulnerabilities. Your team's objective is to identify, patch and exploit these vulnerabilities against other teams to capture flags, all while ensuring the services remain operational and functional.

An Attack/Defense CTF is divided into rounds (or ticks), typically lasting 2 minutes each. At the start of a new round, the checker inserts new flags into each VulnBox and conducts tests for each service. Failure in any test results in a reduction of the service's SLA (Service Level Agreement).



Attack/Defense CTFs - Scoring

Each service in the competition is assigned three types of points:

- **Attack** points: starting from **0**, earned by successfully stealing flags from other teams.
- **Defense** points: these points decrease every time a flag is taken from your VulnBox.
- **SLA** (Service Level Agreement): a multiplier that diminishes each time the service experiences downtime or is unable to function properly in all its capacities.

The total score for each service is calculated using the formula: $(\text{ATK} + \text{DEF}) * \text{SLA}$. It's important to note that this formula is a general representation; each competition may adopt a different formula that incorporates additional factors.

Furthermore, the team's overall score is essentially the sum of all the service scores.

Attack/Defense CTFs - Team Organization

In A/D CTFs, team organization is paramount.

Effective communication is essential for preventing errors that could result in point deductions.

Each team member plays a vital role, with special emphasis on the sysadmin. As the individual responsible for managing the VulnBox and associated tools, the sysadmin requires extensive expertise in Linux OS and proficiency with all team-utilized tools.

Each player must be assigned to a service for the entirety of the CTF. It's highly discouraged to switch services mid-CTF as it leads to significant time loss.

Attack/Defense CTFs - Attacking

Once a vulnerability is discovered, you must develop an exploit script, typically in Python. This script should target all VulnBoxes except your own, and it needs to be executed during every game tick, as the flags change with each tick.

After launching the exploit on a VulnBox, you must submit the obtained flags to the game server. Remember that the flags have a validity of two ticks: therefore, for each tick, the flags inserted by the checker in the current tick and the previous one are valid.

If you find it annoying to do all of this manually every 2 minutes, you're absolutely right.

You need an attacker and a submitter.

No, removing the flag from the service's response won't work

Doing so will result in a decrease in SLA

Attack/Defense CTFs - Defending

But how the checker works?

Let's assume that the flag is placed within the "password" field of a user inside a database.

When the tick starts, the checker does 2 things:

- It runs multiple tests, checking if your service it's functional in all it's features (eg. Registration, login, password change...). Please note that the checker also tries to retrieve the flag in the legit way, without running any exploit.
- It starts registering a bunch of users inside your own service, with the flags provided by the game server as passwords.

Attack/Defense CTFs - Defending

Here's a collection of handy tools ready for use in an A/D CTF:

- [Destructive Farm](#): both attacker and submitter, works really well
- [Caronte](#): Network flow analyzer, quite effective although the latest commit was made two years ago.
- [CTF Proxy](#): HTTP & TCP proxy for your services. Haven't personally tried it yet.

The funny part? All of these tools are developed from ex CyberChallenge players :)

If you want to make things much more entertaining while also challenging yourselves, you could try writing your own tools.

Any Questions?